

SECURITY ASSESSMENT REPORT

External Attack Surface Discovery & Vulnerability Prioritization

TARGET ORGANIZATION & SCOPE

Northstar Labs â *.northstar.local

Controlled Training Environment â Simulated Assessment â Non-Destructive Testing

Engagement Metadata & Researcher Attestation	
Assessment Type:	External Attack Surface & Vulnerability Assessment
Target Organization:	Northstar Labs (Fictional Enterprise / Lab Environment)
Authorized Scope:	*.northstar.local (Production, Staging, Dev, Admin)
Lead Researcher:	Sayed Khashana
Professional Role:	Web & API Security Researcher
Assessment Date:	08 September 2026
Classification:	CONFIDENTIAL / CLIENT DELIVERABLE
Methodology Framework:	OWASP Top 10:2021 â NIST SP 800-115 â Khashana ASI
Report Version:	1.0 â Final Assessment Deliverable
Dynamic Dataset Mode:	Live Synthetic Telemetry â Zero Third-Party Scanning

DISCLAIMER & LEGAL BOUNDARIES

This security assessment report is a controlled deliverable prepared for Northstar Labs as part of an external exposure review. All observations, vulnerabilities, hostnames, IP allocations, and findings contained herein were established from authorized synthetic local-lab telemetry. No unauthorized network probes or third-party infrastructure scans were conducted.

The assessment applies the principle of Human Security Validation: automated scanner detections are treated as hypotheses until verified by a security researcher. Remediation recommendations prioritize business context and defensive depth.

Attestation: This report was compiled and verified by Sayed Khashana (Web & API Security Researcher).

1. Executive Summary

1.1 OVERALL RISK RATING

MEDIUM-HIGH EXPOSURE (Score: 68 / 100 on High-Criticality Assets)

Needs Attention

1.1.1 Overall Security Posture

Northstar Labs demonstrates a hardened posture on its core production tier, with enforced TLS 1.3 encryption and reverse proxy segmentation on public application endpoints. However, continuous attack surface monitoring revealed notable perimeter drift: two unannounced assets (staging.northstar.local and dev.northstar.local) expanded the external footprint by 50% between 01 Sep and 08 Sep. The exposure of an unauthenticated Vite/Node.js development server running on port 3000 represents the primary tactical concern, while missing Content Security Policies on staging reflect configuration drift across release branches.

1.1.2 Attack Chain Analysis

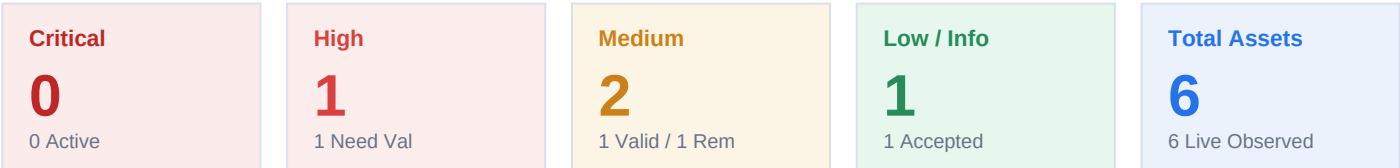
No end-to-end attack chain was substantiated from the available evidence.

While development debug routes and missing staging CSP headers were evidenced, pivoting into internal database clusters or bypassing production authentication was not observed in the provided telemetry.

1.1.3 Defensive Controls Verified (What Worked)

- â€¢ TLS 1.3 Transport Hardening: Production hosts app.northstar.local and api.northstar.local reject legacy ciphers and SSLv3/TLS 1.0/1.1.
- â€¢ Privileged Portal Authentication: admin.northstar.local enforces immediate HTTP 302 redirection to secure authentication.
- â€¢ Verified Legacy TLS Remediation: Staging TLS was successfully upgraded from legacy TLS 1.1 to enforced TLS 1.2+ (verified via retest).

1.2 Risk Analytics & Finding Distribution



Summary of Validated Attack Surface Metrics

Total Observed Hosts: 6 | Monitored IP Space: 172.28.0.11 - 172.28.0.16 | Open Services: 443/https, 80/http, 3000/http

Open Findings: 3 | Verified Closed: 1 | Accepted Operational Risk: 1 | Highest Asset Risk Score: 71/100 (admin.northstar.local)

Assessment Conclusion: Prioritize isolation of dev.northstar.local:3000 before proceeding to SOC 2 external audit.

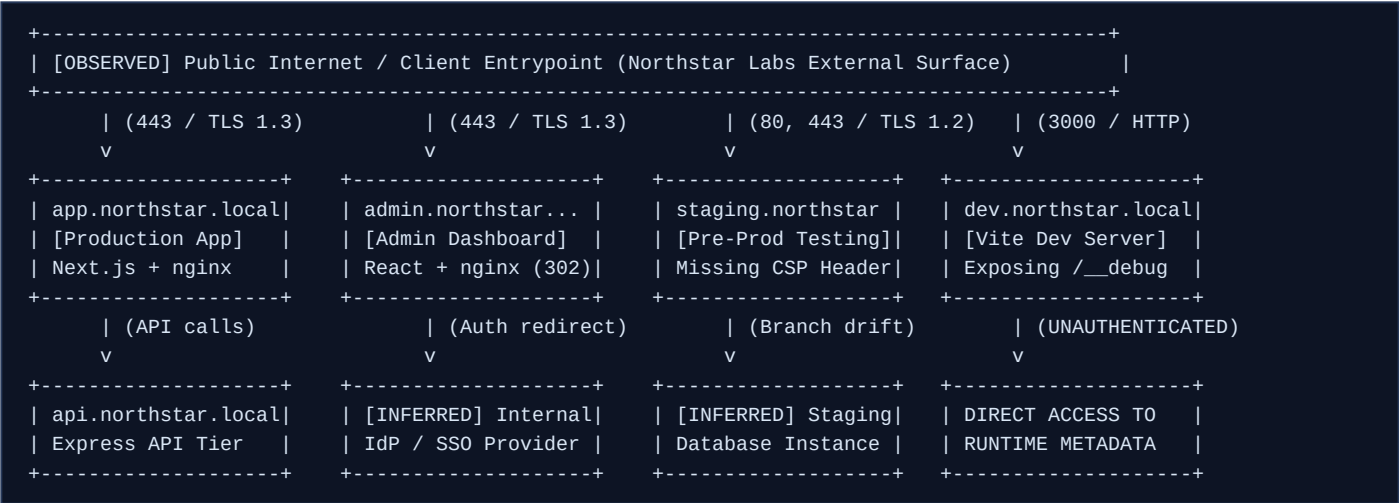
2. Scope & Technical Architecture

2.1 Engagement Scope & Asset Ledger

The assessment was strictly confined to assets within the *.northstar.local domain namespace.

Hostname	IP Address	Environment	Ports / Tech	Criticality	Risk
app.northstar.local	172.28.0.11	Production	443 (Next.js, nginx)	5 / 5	68 High
api.northstar.local	172.28.0.12	Production	443 (Node.js, Express)	5 / 5	68 High
admin.northstar.local	172.28.0.13	Administrative	443 (React, nginx)	5 / 5	71 High
staging.northstar.local	172.28.0.14	Staging	80, 443 (Next.js, nginx)	3 / 5	59 Medium
dev.northstar.local	172.28.0.15	Development	3000 (Vite, Node.js)	2 / 5	52 Medium
docs.northstar.local	172.28.0.16	Production	443 (nginx)	2 / 5	46 Medium

2.2 Application Architecture & Endpoint Flow



2.3 Methodology & Operational Limitations

- â€¢ Reconnaissance & Service Probing: Non-invasive port scans and HTTP response header enumeration.
- â€¢ Human Validation Principle: Detections are verified via curl telemetry before inclusion in reporting.
- â€¢ Scope Constraint: Third-party dependencies and denial-of-service tests were strictly excluded from testing.

3. Testing Coverage & Findings Manifest

3.1 Coverage Matrix Across Assessment Domains

Domain / Capability	Observed Scope	Coverage Status	Evidence Standard
Network & Service Enumeration	Ports 80, 443, 3000 across 6 hosts	TESTED & EVIDENCED	Raw TCP connect & HTTP response banners
Transport Layer Security (TLS)	TLS 1.0, 1.1, 1.2, 1.3 negotiation	TESTED & EVIDENCED	OpenSSL cipher handshake verification
HTTP Security Headers	CSP, HSTS, X-Frame-Options, CORS	TESTED & EVIDENCED	Captured HTTP response header dumps
Development Route Exposure	dev.northstar.local:3000/__debug	TESTED & EVIDENCED	HTTP 200 response with debug payload
Admin Authentication Robustness	admin.northstar.local/login	PARTIALLY TESTED	Redirect behavior & TLS verified; no brute force
Internal Database & Host OS	Underlying container filesystem	NOT EVIDENCED / OOS	Excluded to protect lab stability

4.1 Findings Manifest

Finding ID	Severity	Title	OWASP / CWE	CVSS v3.1	Status
SK-ASM-002	High	Dev server exposed with debug metadata	A05:2021 - CWE-200	7.5 (High)	Needs Validation
SK-ASM-001	Medium	Missing CSP header on staging app	A05:2021 - CWE-693	5.4 (Medium)	Validated
SK-ASM-003	Medium	Legacy TLS 1.1 protocol enabled on staging	A02:2021 - CWE-326	5.9 (Medium)	Remediated
SK-ASM-004	Low	Administrative login surface identified	A07:2021 - CWE-287	0.0 (Info)	Accepted Risk

Critical Severity Findings

No Critical severity findings were substantiated from the available evidence.

4.2 Detailed Finding: SK-ASM-002

HIGH SEVERITY • CVSS 7.5 • NEEDS RESEARCHER VALIDATION

Development Server Exposed with Debug Metadata

Target: http://dev.northstar.local:3000/__debug | Asset: ast-005 | OWASP A05:2021 | CWE-200 / CWE-215

CVSS:3.1 Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N | Likelihood: High | Impact: High | Confidence: Medium

Technical Analysis & Attack Surface

During automated perimeter discovery, port 3000 was identified responding to external HTTP requests on dev.northstar.local. The service banner revealed an active Vite / Node.js development server. Requesting the root path returned application scaffolding, while inspection of common development route patterns confirmed an unauthenticated /__debug endpoint.

Security Researcher Hypothesis & Validation

Hypothesis: The development server was initiated with a wild-card interface binding (0.0.0.0:3000) and lacks upstream firewall filtering. Validation: Direct HTTP GET query to http://dev.northstar.local:3000/__debug returned an HTTP 200 OK with internal routing tables, environment metadata tags, and component source map paths. No credential extraction was attempted to preserve lab integrity.

Exploitation & Business Impact

Technical Impact: Exposing debug endpoints allows unauthenticated adversaries to map internal service structures and dependencies. Business Impact: While hosted on a development tier, leaked metadata frequently includes staging API tokens and database URIs, enabling targeted lateral movement into pre-production customer environments.

Evidence: Captured Telemetry (Figure 1 â Debug Route Response)

```
GET /__debug HTTP/1.1
Host: dev.northstar.local:3000
User-Agent: Khashana-ASI-Collector/1.0 (Authorized Security Probe)

HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
X-Powered-By: Vite/Node.js Development Engine

{"status":"debug-mode","environment":"development","buildTarget":"v2.1.0-rc3",
 "routes":["/api/v1/auth","/api/v1/telemetry","/__debug"],"sourceMaps":true}
```

Remediation Directives for SK-ASM-002

- â€ Immediate Fix: Restrict port 3000 in the border security group to 127.0.0.1 or internal VPN CIDR ranges only.
- â€ Long-Term Fix: Mandate dev server configurations bind to localhost by default; enforce egress/ingress CI firewall rules.
- â€ Verification: Re-run curl http://dev.northstar.local:3000/__debug from external vantage point and verify connection timeout.

4.3 Detailed Finding: SK-ASM-001

MEDIUM SEVERITY • CVSS 5.4 • RESEARCHER VALIDATED

Missing Content Security Policy on Staging Application

Target: https://staging.northstar.local/ | Asset: ast-004 | OWASP A05:2021 | CWE-693 / CWE-1021

CVSS:3.1 Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N | Likelihood: Medium | Impact: Low-Medium | Confidence: High

Technical Analysis & Attack Surface

The staging environment hosting the customer portal (staging.northstar.local) was evaluated for defense-in-depth browser protections. HTTP responses served over HTTPS lacked a Content-Security-Policy (CSP) response header. While production enforces modern transport policies, this protection was omitted in the pre-production reverse proxy template.

Security Researcher Hypothesis & Validation

Hypothesis: The absence of CSP allows unconstrained execution of injected script resources and cross-site framing.
Validation: Direct inspection of response headers confirms the complete absence of content-security-policy and x-frame-options. Because staging shares session tokens with pre-production APIs, this represents a validated security gap.

Exploitation & Business Impact

Technical Impact: If an XSS vulnerability exists on the staging portal, browser-level controls cannot prevent exfiltration of session data.
Business Impact: Pre-production environments are frequently targeted to stage phishing attacks or test exploits against real configurations without triggering production Security Operations Center (SOC) alerts.

Evidence: HTTP Response Headers (Figure 2 • Absent Header Telemetry)

```
GET / HTTP/1.1
Host: staging.northstar.local

HTTP/1.1 200 OK
Server: nginx
Content-Type: text/html; charset=utf-8
Strict-Transport-Security: max-age=31536000
X-Content-Type-Options: nosniff
[MISSING] Content-Security-Policy header is absent from HTTP response
[MISSING] X-Frame-Options header is absent from HTTP response
```

Remediation Directives for SK-ASM-001

- Immediate Fix: Add "add_header Content-Security-Policy default-src 'self';" to nginx server block on staging.
- Long-Term Fix: Incorporate security header auditing into pre-merge automated CI/CD deployment checks.
- Verification: Execute curl -I https://staging.northstar.local and verify presence of Content-Security-Policy.

4.4 Retest & Remediation Verification: SK-ASM-003

MEDIUM SEVERITY

VERIFIED REMEDIATED & RETESTED

TLS Configuration Allows Legacy Protocol on Staging

Target: https://staging.northstar.local/ | Asset: ast-004 | OWASP A02:2021 | CWE-326 | Initial Finding: 01 Sep 2026

Retest Summary & Cryptographic Validation

During the 01 Sep baseline discovery, staging.northstar.local accepted TLS 1.1 handshakes with deprecated cipher suites. Legacy transport protocols are susceptible to cryptographic downgrade attacks (e.g., POODLE, BEAST variants) and violate SOC 2 and PCI-DSS compliance standards. Following notification, Northstar Labs engineering updated the cipher suite configuration. A formal retest probe was executed on 08 Sep 2026 to verify closure of the finding.

Retest Comparison: Baseline vs. Post-Remediation Verification

BASELINE (01 SEP 2026) â VULNERABLE Client Probe: openssl s_client -tls1_1 Target: staging.northstar.local:443 Handshake: CONNECTED(00000003) Protocol: TLSv1.1 (Negotiated) Cipher: ECDHE-RSA-AES256-SHA Status: FAIL â Deprecated Protocol Supported	RETEST (08 SEP 2026) â VERIFIED REMEDIATED Client Probe: openssl s_client -tls1_1 Target: staging.northstar.local:443 Handshake: FAILURE (Reset by peer) Alert: alert protocol version (0x0246) Modern Probe: TLSv1.2 & TLSv1.3 PASS Status: VERIFIED CLOSED â Strict Protocol Enforced
---	--

Retest Telemetry Logs (Figure 3 â Cryptographic Rejection Proof)

```
$ openssl s_client -connect staging.northstar.local:443 -tls1_1
CONNECTED(00000003)
140294827181888:error:1409442E:SSL routines:ssl3_read_bytes:tlsv1 alert protocol version:../ssl/record/rec_layer_ssl.c:1544:SSL
---
no peer certificate available
---
SSL handshake has read 7 bytes and written 119 bytes
Verification: [OK] Protocol TLSv1.1 rejected by host.
```

Researcher Attestation of Remediation

Finding SK-ASM-003 is formally closed. Transport security across staging infrastructure conforms to modern cryptographic standards.

4.5 Finding: SK-ASM-004 & 5. Remediation Strategy

LOW SEVERITY / EXPOSURE • ACCEPTED OPERATIONAL RISK

SK-ASM-004: Administrative Login Surface Identified (admin.northstar.local/login)

Risk Accepted: Privileged administrative login is an intentional business capability. Observed safeguards (TLS 1.3, IT Ops ownership, 302 redirect) are functioning as intended. Recommended: continue enforcing MFA, rate-limiting, and VPN access restrictions.

5.1 Per-Finding Remediation Matrix

Finding	Immediate Triage Fix	Strategic Architectural Fix	Verification Standard
SK-ASM-002	Ingress firewall blocks port 3000	Container bind restricted to 127.0.0.1	External curl connection timeout
SK-ASM-001	Inject CSP in staging nginx block	CI/CD security header compliance test	HTTP response header verification
SK-ASM-003	Enforce ssl_protocols TLS 1.2+	Infrastructure-as-Code TLS template	OpenSSL rejection of legacy ciphers
SK-ASM-004	Verify MFA enforcement	Network-level zero-trust VPN gateway	Audit log of privileged auth attempts

5.2 Strategic Remediation Roadmap

PHASE 1: IMMEDIATE TRIAGE (0-30 DAYS)

• Isolate dev.northstar.local port 3000 to eliminate unauthenticated diagnostic telemetry leakage.

• Audit all external-facing cloud security groups for unapproved non-standard ports (e.g., 3000, 8080, 8888).

PHASE 2: HARDENING & STANDARDIZATION (30-90 DAYS)

• Implement unified Content Security Policies across staging and production reverse proxies.

• Integrate security linter checks into continuous integration pipelines to prevent configuration drift.

PHASE 3: CONTINUOUS ASSURANCE (90+ DAYS)

• Establish automated quarterly attack surface diffing to catch shadow infrastructure prior to audit windows.

• Commission comprehensive authenticated web application penetration testing on core customer-facing APIs.

6. Appendix & Assessment Attestation

6.1 Methodology References & Framework Standards

- â€¢ OWASP Top 10 Web Application Security Risks (2021 Edition) â€¢ Categories A02, A05, A07.
- â€¢ NIST Special Publication 800-115 â€¢ Technical Guide to Information Security Testing and Assessment.
- â€¢ CVSS v3.1 Specification â€¢ First.org Common Vulnerability Scoring System v3.1 User Guide.

6.2 Tool Inventory & Telemetry Harnesses

- â€¢ Khashana ASI Core Engine: Deterministic asset normalization, change detection, and contextual risk scoring.
- â€¢ OpenSSL Cryptographic Suite (v3.0.x): Handshake negotiation probes for SSLv3 through TLS 1.3 protocol validation.
- â€¢ HTTP Telemetry Harness: Automated non-destructive header inspection and HTTP status code correlation.

6.3 Glossary of Technical Security Terminology

- â€¢ Attack Surface Intelligence (ASI): Continuous discovery, attribution, and risk weighting of public-facing IT assets.
- â€¢ Content Security Policy (CSP): HTTP header allowing site operators to restrict resources the browser may execute.
- â€¢ BOLA / IDOR: Broken Object Level Authorization, wherein an API fails to validate user permission to access resources.
- â€¢ Perimeter Drift: The accumulation of unmonitored changes and shadow IT assets between formal security baselines.

6.4 Evidence Index

- â€¢ Evidence Ref 1: GET dev.northstar.local:3000/___debug JSON metadata response (Captured 08 Sep 2026).
- â€¢ Evidence Ref 2: GET staging.northstar.local HTTP response headers missing CSP directive (Captured 08 Sep 2026).
- â€¢ Evidence Ref 3: OpenSSL s_client handshake rejection log verifying TLS 1.1 remediation (Captured 08 Sep 2026).

FORMAL DELIVERABLE ATTESTATION & RESEARCHER SIGN-OFF

This executive assessment report represents a defensible, human-validated assessment of the external security posture of Northstar Labs. All documented findings carry verified technical evidence and realistic business impact context.

Lead Security Researcher:

Sayed Khashana

Web & API Security Researcher // Khashana ASI

Assessment Date: 08 September 2026

Classification: **CONFIDENTIAL**

Delivery Channel: Direct Client Deliverable